# WAPT Phase 1: Task 2, Recon and Enumeration

Kitula James

October 2026


- IqraSec Academy
  - Web Application Penetration Testing (WAPT), Phase 1
- 1. Objective
- 2. Concept / Understanding
- 3. Practical Work
- 4. Tools Used
- 5. Evidence
  - 5.1 Passive Recon
  - 5.2 Active Recon
  - 5.3 Content Discovery
- 6. Result
- 7. Key Learnings
- Appendix: Commands Used


# IqraSec Academy

## Web Application Penetration Testing (WAPT), Phase 1

### Task 2: Reconnaissance and Enumeration

| | |
|---|---|
| **Prepared by** | Kitula James |
| **Contact** | kitulajames3@gmail.com |
| **Rooms completed** | Passive Recon, Active Recon, Content Discovery (TryHackMe) |
| **Platform** | TryHackMe, Kali Linux |
| **Date** | October 2026 |

**Scope:** the three TryHackMe rooms above. Passive checks used public sources only. All active scans (ping, traceroute, telnet, netcat, Gobuster) were run only against the rooms' own lab machines.

**Disclaimer:** all testing was done on legal training platforms for educational purposes. No personal data or credentials are included.

# 1. Objective

To map the attack surface of a target before testing it: identify technology, subdomains, directories, hidden functionality and exposed services, first passively and then actively.

# 2. Concept / Understanding

| Area | What I learned |
|---|---|
| Passive vs active recon | Passive uses public sources only and sends nothing to the target. Active touches the target, leaves logs, and needs written authorisation. |
| WHOIS and DNS | whois shows registrar, dates, name servers and status. DNS records (A, MX, TXT, NS) show IPs, mail and verification data. |
| Subdomain discovery | DNSDumpster and crt.sh (certificate transparency logs) find subdomains without touching the target. |
| Shodan | Indexes exposed devices, open ports and service banners. |
| ping, traceroute | ping shows reachability and the TTL hints at the OS. traceroute maps the router path. |
| telnet, netcat | Banner grabbing: connect to a port and read the software and version. |
| Manual discovery | robots.txt, sitemap.xml, response headers and the framework's documentation reveal hidden paths and default admin portals. |
| OSINT | Google dorks, Wappalyzer, Wayback Machine, GitHub and S3 buckets expose forgotten content. |
| Gobuster | dir mode finds hidden files and folders, dns mode finds subdomains, vhost mode finds virtual hosts through the Host header. |

# 3. Practical Work

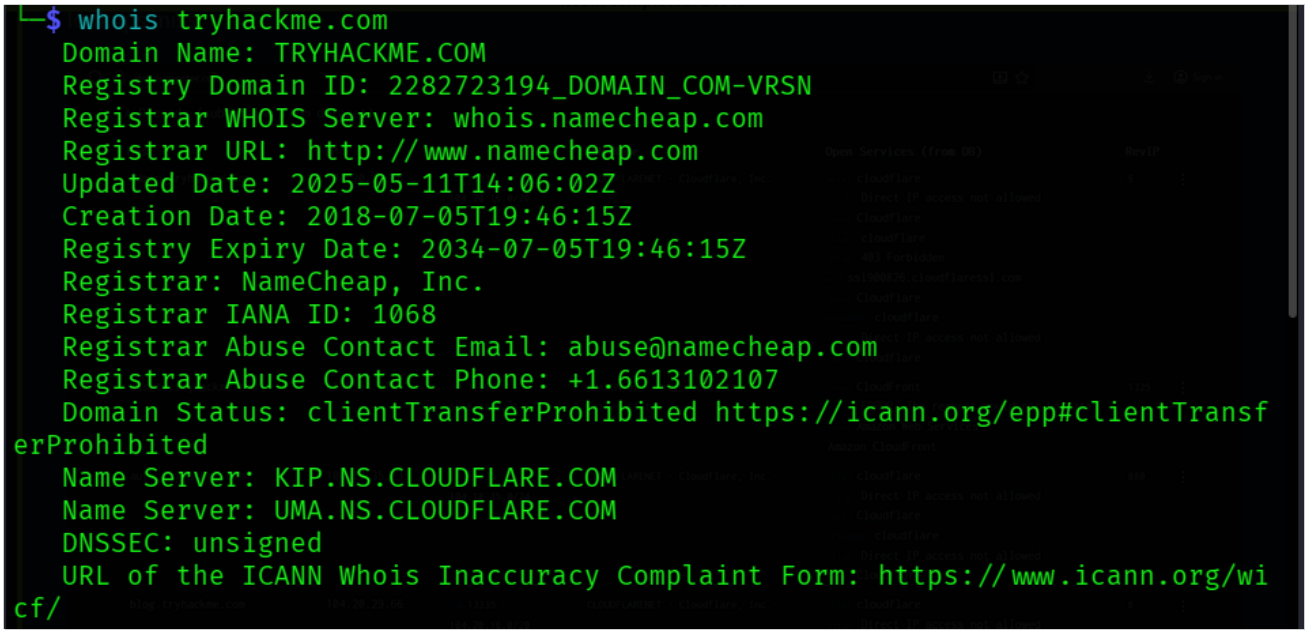
| Room | What I did |
|---|---|
| Passive Recon | Ran `whois`, `dig` (A, MX, TXT), `nslookup` and an RDAP query on tryhackme.com. Found subdomains with crt.sh and DNSDumpster and read exposed services in Shodan. Repeated the lookups on example.com for comparison. |
| Active Recon | Pinged a lab machine (10 of 10 replies, TTL 62), traced the route, grabbed web banners with telnet and curl (`Server: nginx/1.22.1`), and read an FTP banner with netcat. Tested a netcat listener on my own machine. |
| Content Discovery | Read robots.txt and sitemap.xml, inspected response headers, followed the framework documentation to its admin portal, then ran Gobuster dir and vhost scans and answered the OSINT questions. |

# 4. Tools Used

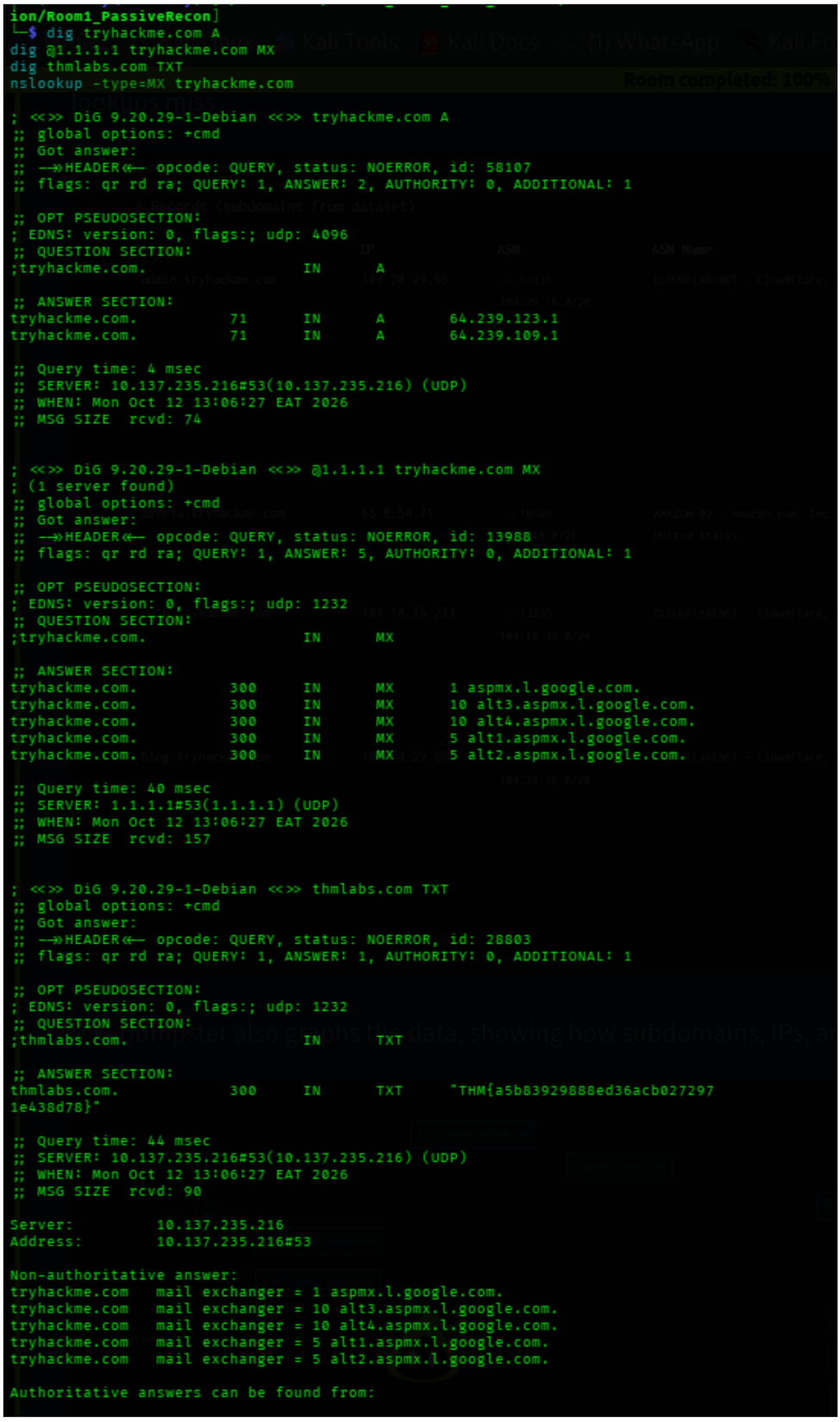
whois, dig, nslookup, curl and jq (RDAP), crt.sh, DNSDumpster, Shodan, ping, traceroute, telnet, netcat, Gobuster, SecLists wordlists, browser DevTools, Kali Linux.

# 5. Evidence

## 5.1 Passive Recon




whois output



```
ion/Room1_PassiveRecon]
└─$ dig tryhackme.com A
dig @1.1.1.1 tryhackme.com MX
dig thmlabs.com TXT
nslookup -type=MX tryhackme.com

; <<>> DiG 9.20.29-1-Debian <<>> tryhackme.com A
;; global options: +cmd
;; Got answer:
;; ->>HEADER<<- opcode: QUERY, status: NOERROR, id: 58107
;; flags: qr rd ra; QUERY: 1, ANSWER: 2, AUTHORITY: 0, ADDITIONAL: 1

;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags:; udp: 4096
;; QUESTION SECTION:
;tryhackme.com.                 IN      A

;; ANSWER SECTION:
tryhackme.com.          71      IN      A       64.239.123.1
tryhackme.com.          71      IN      A       64.239.109.1

;; Query time: 4 msec
;; SERVER: 10.137.235.216#53(10.137.235.216) (UDP)
;; WHEN: Mon Oct 12 13:06:27 EAT 2026
;; MSG SIZE  rcvd: 74


; <<>> DiG 9.20.29-1-Debian <<>> @1.1.1.1 tryhackme.com MX
; (1 server found)
;; global options: +cmd
;; Got answer:
;; ->>HEADER<<- opcode: QUERY, status: NOERROR, id: 13988
;; flags: qr rd ra; QUERY: 1, ANSWER: 5, AUTHORITY: 0, ADDITIONAL: 1

;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags:; udp: 1232
;; QUESTION SECTION:
;tryhackme.com.                 IN      MX

;; ANSWER SECTION:
tryhackme.com.          300     IN      MX      1 aspmx.l.google.com.
tryhackme.com.          300     IN      MX      10 alt3.aspmx.l.google.com.
tryhackme.com.          300     IN      MX      10 alt4.aspmx.l.google.com.
tryhackme.com.          300     IN      MX      5 alt1.aspmx.l.google.com.
tryhackme.com.          300     IN      MX      5 alt2.aspmx.l.google.com.

;; Query time: 40 msec
;; SERVER: 1.1.1.1#53(1.1.1.1) (UDP)
;; WHEN: Mon Oct 12 13:06:27 EAT 2026
;; MSG SIZE  rcvd: 157


; <<>> DiG 9.20.29-1-Debian <<>> thmlabs.com TXT
;; global options: +cmd
;; Got answer:
;; ->>HEADER<<- opcode: QUERY, status: NOERROR, id: 28803
;; flags: qr rd ra; QUERY: 1, ANSWER: 1, AUTHORITY: 0, ADDITIONAL: 1

;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags:; udp: 1232
;; QUESTION SECTION:
;thmlabs.com.                   IN      TXT

;; ANSWER SECTION:
thmlabs.com.            300     IN      TXT     "THM{a5b83929888ed36acb027297
1e438d78}"

;; Query time: 44 msec
;; SERVER: 10.137.235.216#53(10.137.235.216) (UDP)
;; WHEN: Mon Oct 12 13:06:27 EAT 2026
;; MSG SIZE  rcvd: 90

Server:         10.137.235.216
Address:        10.137.235.216#53

Non-authoritative answer:
tryhackme.com   mail exchanger = 1 aspmx.l.google.com.
tryhackme.com   mail exchanger = 10 alt3.aspmx.l.google.com.
tryhackme.com   mail exchanger = 10 alt4.aspmx.l.google.com.
tryhackme.com   mail exchanger = 5 alt1.aspmx.l.google.com.
tryhackme.com   mail exchanger = 5 alt2.aspmx.l.google.com.

Authoritative answers can be found from:
```

dig and nslookup output

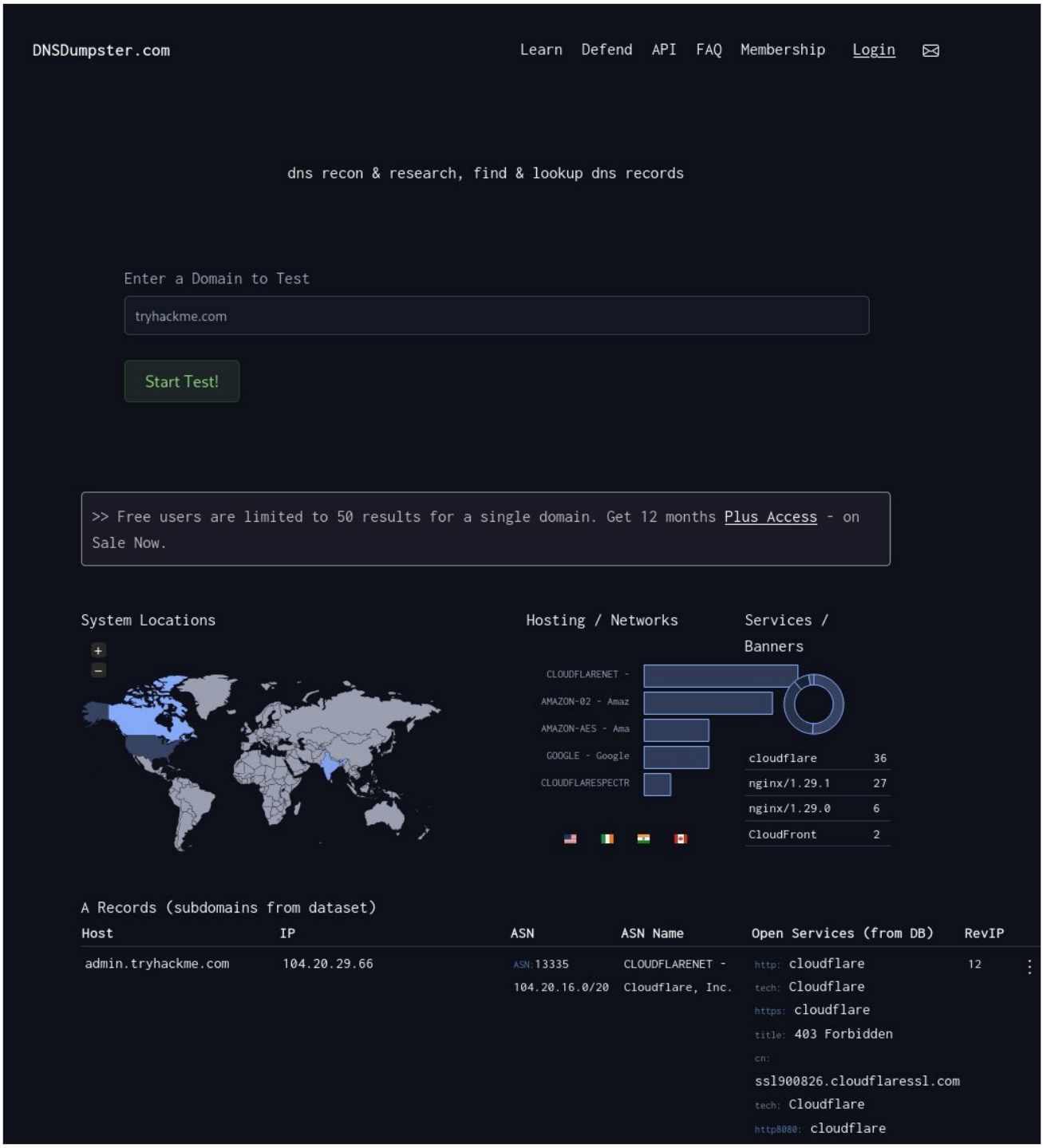
crt.sh **Identity Search** Group by Issuer

| Criteria | Type: Identity Match: ILIKE Search: 'tryhackme.com' |
|---|---|

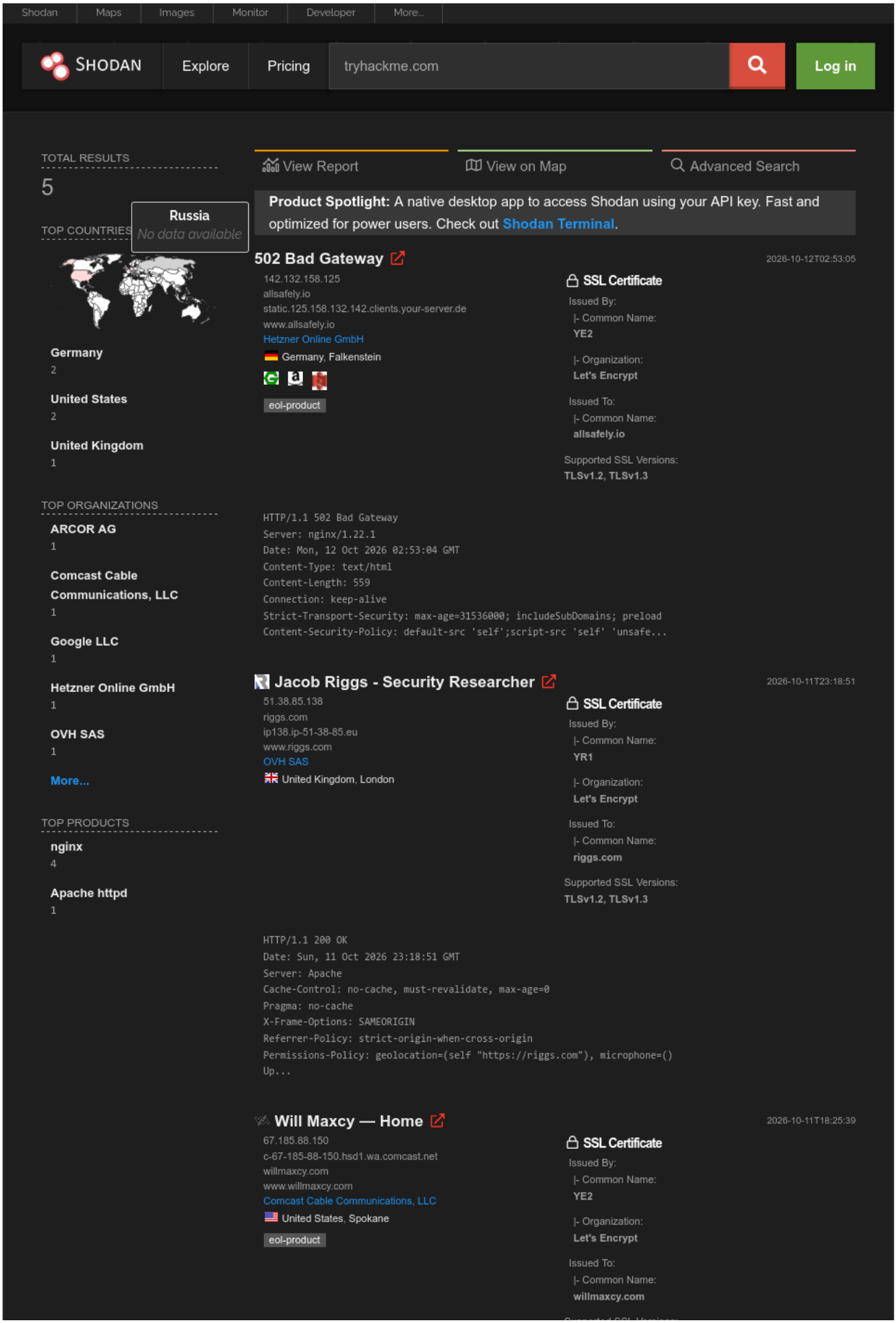
Certificates

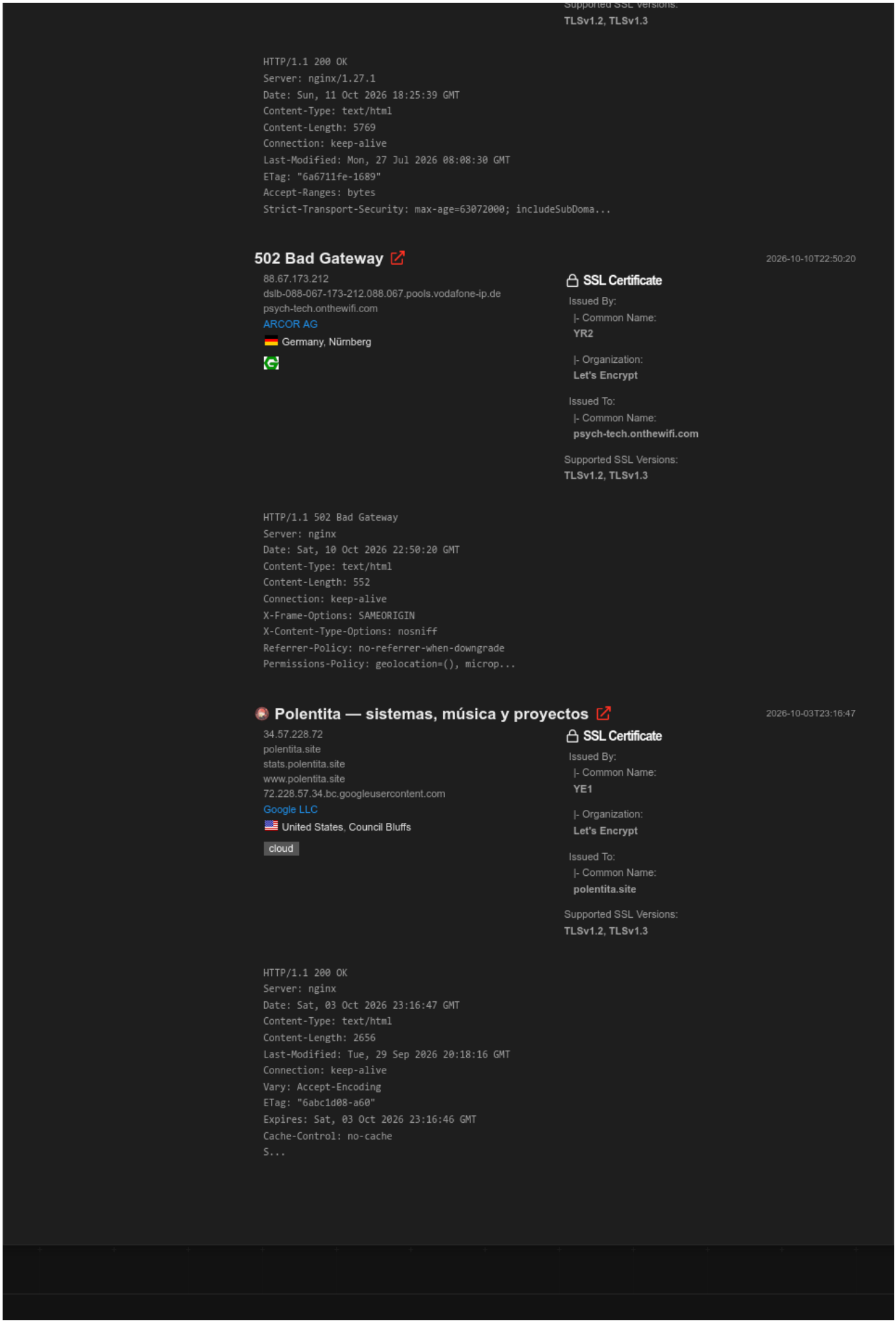
| crt.sh ID | Not Before ⇧ | Not After | Common Name | Matching Identities | Issuer Name |
|---|---|---|---|---|---|
| 29712245289 | 2026-10-01 | 2027-04-16 | costra.vm.tryhackme.com | costra.vm.tryhackme.com | C=US, O=Amazon, CN=Amazon RSA 2048 M01 |
| 29623652052 | 2026-09-26 | 2026-12-25 | tryhackme.com | tryhackme.com | C=US, O=Let's Encrypt, CN=YR1 |
| 29523830575 | 2026-09-18 | 2026-12-17 | lp.tryhackme.com | lp.tryhackme.com | C=US, O=Google Trust Services, CN=WE1 |
| 29348363873 | 2026-09-10 | 2026-12-09 | click.tryhackme.com | click.tryhackme.com | C=US, O=Google Trust Services, CN=WR3 |
| 29339312256 | 2026-09-04 | 2026-12-03 | proxy.lb-architect.tryhackme.com | proxy.lb-architect.tryhackme.com | C=US, O=Let's Encrypt, CN=YE1 |
| 29660729512 | 2026-09-04 | 2026-10-04 | careers.tryhackme.com | careers.tryhackme.com | C=US, O=Certainly, CN=Certainly Intermediate R1 |
| 29623594536 | 2026-09-03 | 2026-12-02 | help.tryhackme.com | help.tryhackme.com | C=US, O=Google Trust Services, CN=WE1 |
| 29111092608 | 2026-08-27 | 2026-11-25 | *.guacaworker.tryhackme.com | *.guacaworker.tryhackme.com<br>guacaworker.tryhackme.com | C=US, O=Google Trust Services, CN=WE1 |
| 29250422791 | 2026-08-27 | 2026-11-25 | *.guacaworker.tryhackme.com | *.guacaworker.tryhackme.com<br>guacaworker.tryhackme.com | C=US, O=Google Trust Services, CN=WR1 |
| 29250014901 | 2026-08-27 | 2026-11-25 | *.guacaworker.tryhackme.com | *.guacaworker.tryhackme.com<br>guacaworker.tryhackme.com | C=US, O=Google Trust Services, CN=WE1 |
| 29369111617 | 2026-08-27 | 2026-11-25 | *.guacaworker.tryhackme.com | *.guacaworker.tryhackme.com<br>guacaworker.tryhackme.com | C=US, O=Google Trust Services, CN=WR1 |
| 29105614206 | 2026-08-27 | 2026-11-25 | desc.tryhackme.com | desc.tryhackme.com | C=US, O=Let's Encrypt, CN=YR2 |
| 29264476434 | 2026-08-27 | 2026-11-25 | desc.tryhackme.com | desc.tryhackme.com | C=US, O=Let's Encrypt, CN=YR2 |
| 29042458253 | 2026-08-23 | 2026-11-21 | e5e27f40.sni.cloudflaressl.com | resources.tryhackme.com | C=US, O=Let's Encrypt, CN=YE2 |
| 29114840315 | 2026-08-23 | 2026-11-21 | e5e27f40.sni.cloudflaressl.com | resources.tryhackme.com | C=US, O=Let's Encrypt, CN=YE2 |
| 29049453975 | 2026-08-23 | 2026-11-21 | e5e27f40.sni.cloudflaressl.com | resources.tryhackme.com | C=US, O=Let's Encrypt, CN=YR1 |
| 29171572516 | 2026-08-23 | 2026-11-21 | e5e27f40.sni.cloudflaressl.com | resources.tryhackme.com | C=US, O=Let's Encrypt, CN=YR1 |
| 29165738872 | 2026-08-23 | 2026-11-21 | e5e27f40.sni.cloudflaressl.com | resources.tryhackme.com | C=US, O=Let's Encrypt, CN=YE2 |
| 29402960814 | 2026-08-23 | 2026-11-21 | e5e27f40.sni.cloudflaressl.com | resources.tryhackme.com | C=US, O=Let's Encrypt, CN=YE2 |
| 29039072225 | 2026-08-23 | 2026-11-21 | e5e27f40.sni.cloudflaressl.com | resources.tryhackme.com | C=US, O=Let's Encrypt, CN=YR1 |
| 29138240002 | 2026-08-23 | 2026-11-21 | e5e27f40.sni.cloudflaressl.com | resources.tryhackme.com | C=US, O=Let's Encrypt, CN=YR1 |
| 29110372842 | 2026-08-22 | 2026-11-18 | tryhackme.com | *.tryhackme.com<br>tryhackme.com | C=GB, O=Sectigo Limited, CN=Sectigo Public Server Authentication CA DV R36 |
| 29110371955 | 2026-08-22 | 2026-11-18 | tryhackme.com | *.tryhackme.com<br>tryhackme.com | C=GB, O=Sectigo Limited, CN=Sectigo Public Server Authentication CA DV R36 |
| 29163957871 | 2026-08-21 | 2026-11-19 | tryhackme.com | *.flowcheck.tryhackme.com<br>flowcheck.tryhackme.com<br>tryhackme.com | C=US, O=Google Trust Services, CN=WE1 |
| 29126179409 | 2026-08-21 | 2026-11-19 | tryhackme.com | *.flowcheck.tryhackme.com<br>flowcheck.tryhackme.com<br>tryhackme.com | C=US, O=Google Trust Services, CN=WR1 |

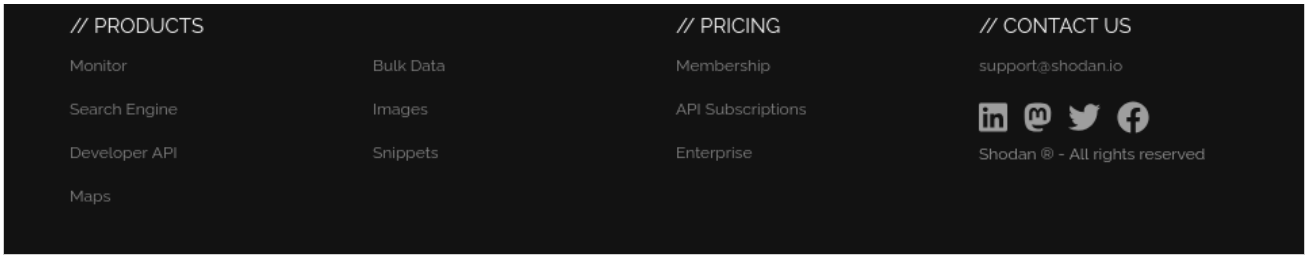
crt.sh subdomain search




DNSDumpster result


Shodan
Maps
Images
Monitor
Developer
More...
SHODAN
Explore
Pricing
tryhackme.com
Log in
TOTAL RESULTS
5
TOP COUNTRIES
Russia
No data available
Germany
2
United States
2
United Kingdom
1
TOP ORGANIZATIONS
ARCOR AG
1
Comcast Cable Communications, LLC
1
Google LLC
1
Hetzner Online GmbH
1
OVH SAS
1
More...
TOP PRODUCTS
nginx
4
Apache httpd
1
View Report
View on Map
Advanced Search
Product Spotlight: A native desktop app to access Shodan using your API key. Fast and optimized for power users. Check out Shodan Terminal.
502 Bad Gateway
2026-10-12T02:53:05
142.132.158.125
allsafely.io
static.125.158.132.142.clients.your-server.de
www.allsafely.io
Hetzner Online GmbH
Germany, Falkenstein
eol-product
SSL Certificate
Issued By:
|- Common Name:
YE2
|- Organization:
Let's Encrypt
Issued To:
|- Common Name:
allsafely.io
Supported SSL Versions:
TLSv1.2, TLSv1.3
HTTP/1.1 502 Bad Gateway
Server: nginx/1.22.1
Date: Mon, 12 Oct 2026 02:53:04 GMT
Content-Type: text/html
Content-Length: 559
Connection: keep-alive
Strict-Transport-Security: max-age=31536000; includeSubDomains; preload
Content-Security-Policy: default-src 'self';script-src 'self' 'unsafe...
Jacob Riggs - Security Researcher
2026-10-11T23:18:51
51.38.85.138
riggs.com
ip138.ip-51-38-85.eu
www.riggs.com
OVH SAS
United Kingdom, London
SSL Certificate
Issued By:
|- Common Name:
YR1
|- Organization:
Let's Encrypt
Issued To:
|- Common Name:
riggs.com
Supported SSL Versions:
TLSv1.2, TLSv1.3
HTTP/1.1 200 OK
Date: Sun, 11 Oct 2026 23:18:51 GMT
Server: Apache
Cache-Control: no-cache, must-revalidate, max-age=0
Pragma: no-cache
X-Frame-Options: SAMEORIGIN
Referrer-Policy: strict-origin-when-cross-origin
Permissions-Policy: geolocation=(self "https://riggs.com"), microphone=()
Up...
Will Maxcy — Home
2026-10-11T18:25:39
67.185.88.150
c-67-185-88-150.hsd1.wa.comcast.net
willmaxcy.com
www.willmaxcy.com
Comcast Cable Communications, LLC
United States, Spokane
eol-product
SSL Certificate
Issued By:
|- Common Name:
YE2
|- Organization:
Let's Encrypt
Issued To:
|- Common Name:
willmaxcy.com


Supported SSL Versions:
TLSv1.2, TLSv1.3
HTTP/1.1 200 OK
Server: nginx/1.27.1
Date: Sun, 11 Oct 2026 18:25:39 GMT
Content-Type: text/html
Content-Length: 5769
Connection: keep-alive
Last-Modified: Mon, 27 Jul 2026 08:08:30 GMT
ETag: "6a6711fe-1689"
Accept-Ranges: bytes
Strict-Transport-Security: max-age=63072000; includeSubDoma...
502 Bad Gateway
2026-10-10T22:50:20
88.67.173.212
dslb-088-067-173-212.088.067.pools.vodafone-ip.de
psych-tech.onthewifi.com
ARCOR AG
Germany, Nürnberg
SSL Certificate
Issued By:
|- Common Name:
YR2
|- Organization:
Let's Encrypt
Issued To:
|- Common Name:
psych-tech.onthewifi.com
Supported SSL Versions:
TLSv1.2, TLSv1.3
HTTP/1.1 502 Bad Gateway
Server: nginx
Date: Sat, 10 Oct 2026 22:50:20 GMT
Content-Type: text/html
Content-Length: 552
Connection: keep-alive
X-Frame-Options: SAMEORIGIN
X-Content-Type-Options: nosniff
Referrer-Policy: no-referrer-when-downgrade
Permissions-Policy: geolocation=(), microp...
Polentita — sistemas, música y proyectos
2026-10-03T23:16:47
34.57.228.72
polentita.site
stats.polentita.site
www.polentita.site
72.228.57.34.bc.googleusercontent.com
Google LLC
United States, Council Bluffs
cloud
SSL Certificate
Issued By:
|- Common Name:
YE1
|- Organization:
Let's Encrypt
Issued To:
|- Common Name:
polentita.site
Supported SSL Versions:
TLSv1.2, TLSv1.3
HTTP/1.1 200 OK
Server: nginx
Date: Sat, 03 Oct 2026 23:16:47 GMT
Content-Type: text/html
Content-Length: 2656
Last-Modified: Tue, 29 Sep 2026 20:18:16 GMT
Connection: keep-alive
Vary: Accept-Encoding
ETag: "6abc1d08-a60"
Expires: Sat, 03 Oct 2026 23:16:46 GMT
Cache-Control: no-cache
S...

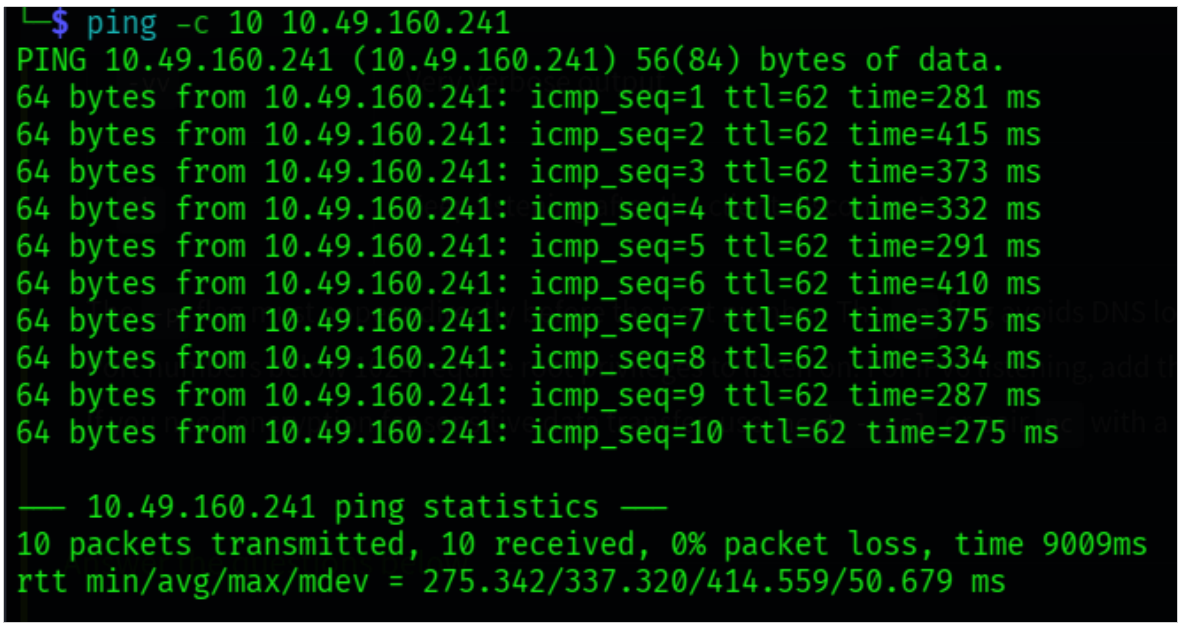



Shodan facets

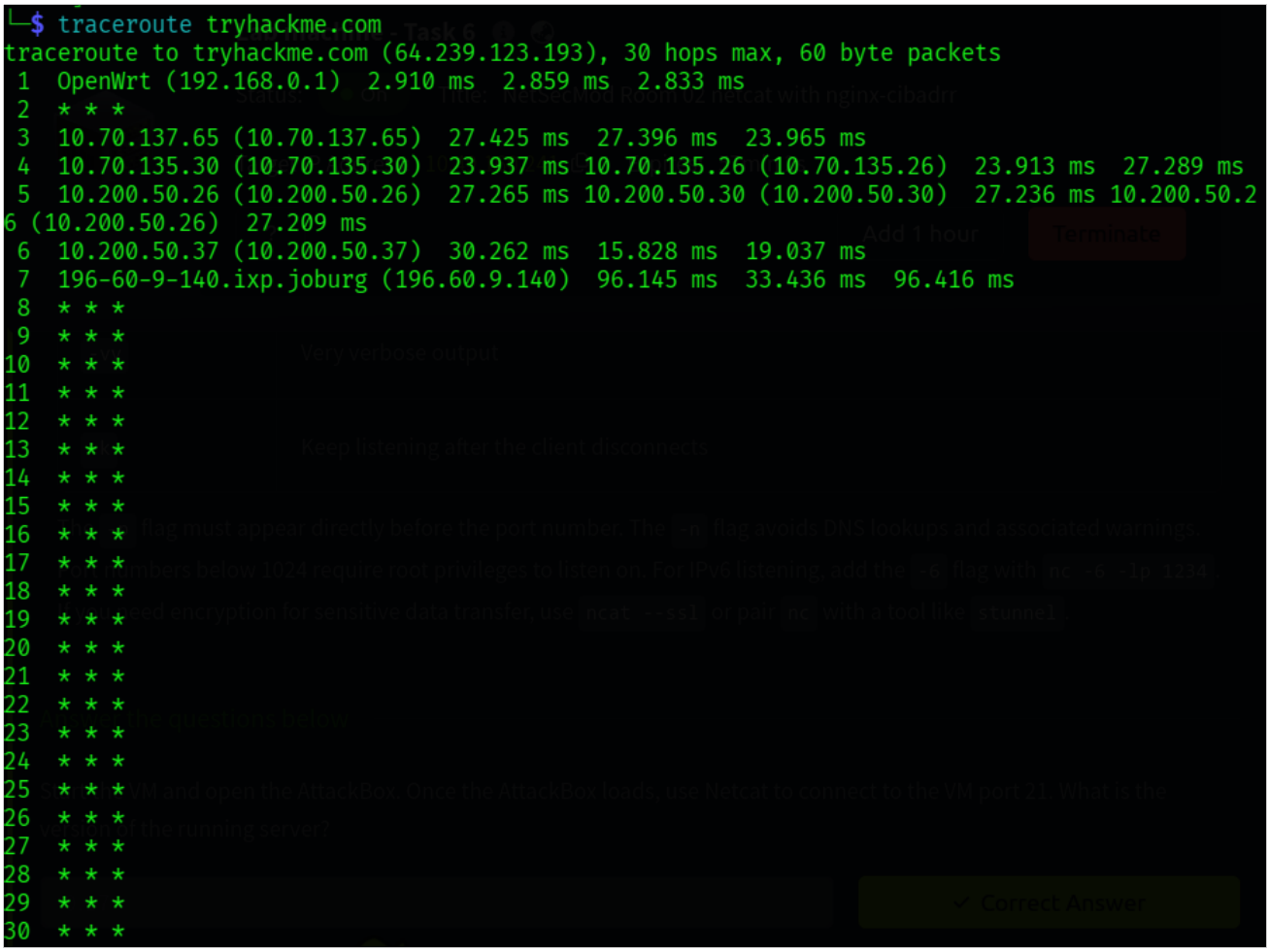



Passive Recon completed

## 5.2 Active Recon




ping output




traceroute output

```
└─$ telnet 10.49.160.241 80
Trying 10.49.160.241 ...
Connected to 10.49.160.241.
Escape character is '^]'.
GET / HTTP/1.1
host: telnet

HTTP/1.1 200 OK
Server: nginx/1.22.1
Date: Tue, 13 Oct 2026 07:56:06 GMT
Content-Type: text/html
Content-Length: 867
Last-Modified: Fri, 08 Oct 2021 04:30:27 GMT
Connection: keep-alive
ETag: "615fc963-363"
Accept-Ranges: bytes

<!DOCTYPE html>
<html>
<head>
<title>Welcome to nginx on Debian!</title>
<style>
    body {
        width: 35em;
        margin: 0 auto;
        font-family: Tahoma, Verdana, Arial, sans-serif;
    }
</style>
</head>
<body>
<h1>Welcome to nginx on Debian!</h1>
<p>If you see this page, the nginx web server is successfully installed and
working on Debian. Further configuration is required.</p>

<p>For online documentation and support please refer to
<a href="http://nginx.org/">nginx.org</a></p>

<p>
      Please use the <tt>reportbug</tt> tool to report bugs in the
      nginx package with Debian. However, check <a
      href="http://bugs.debian.org/cgi-bin/pkgreport.cgi?ordering=normal;archive=0;src=nginx;
repeatmerged=0">existing
      bug reports</a> before reporting a new bug.
</p>

<p><em>Thank you for using debian and nginx.</em></p>
```

telnet banner grab

```
└─$ nc 10.49.160.241 21
220 ip-10-49-160-241.ap-south-1.compute.internal FTP server (Version 6.4/OpenBSD/Linux-ftpd-0
.17) ready.
```

netcat FTP banner



Active Recon completed

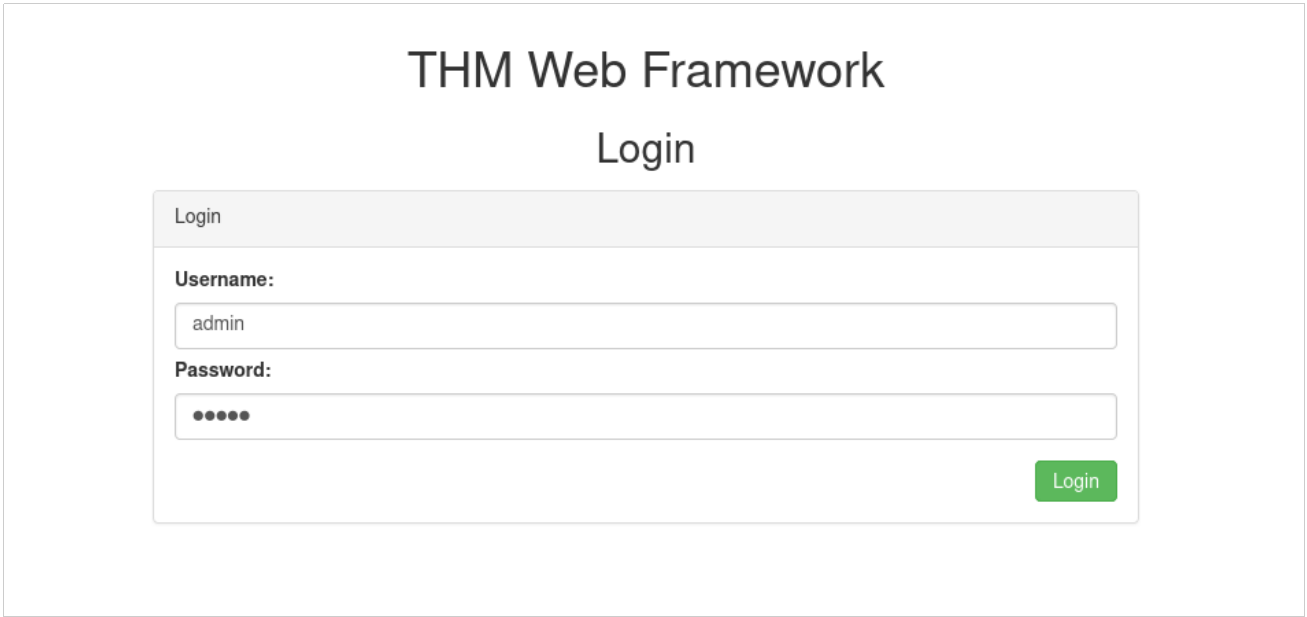
## 5.3 Content Discovery

```
−<urlset>
  −<url>
      <loc>http://10.49.183.225/</loc>
      <lastmod>2021-07-19T13:07:32+00:00</lastmod>
      <priority>1.00</priority>
    </url>
  −<url>
      <loc>http://10.49.183.225/news</loc>
      <lastmod>2021-07-19T13:07:32+00:00</lastmod>
      <priority>0.80</priority>
    </url>
  −<url>
      <loc>http://10.49.183.225/news/article?id=1</loc>
      <lastmod>2021-07-19T13:07:32+00:00</lastmod>
      <priority>0.80</priority>
    </url>
  −<url>
      <loc>http://10.49.183.225/news/article?id=2</loc>
      <lastmod>2021-07-19T13:07:32+00:00</lastmod>
      <priority>0.80</priority>
    </url>
  −<url>
      <loc>http://10.49.183.225/news/article?id=3</loc>
      <lastmod>2021-07-19T13:07:32+00:00</lastmod>
      <priority>0.80</priority>
    </url>
  −<url>
      <loc>http://10.49.183.225/contact</loc>
      <lastmod>2021-07-19T13:07:32+00:00</lastmod>
      <priority>0.80</priority>
    </url>
  −<url>
      <loc>http://10.49.183.225/customers/login</loc>
      <lastmod>2021-07-19T13:07:32+00:00</lastmod>
      <priority>0.80</priority>
    </url>
  −<url>
      <loc>http://10.49.183.225/s3cr3t-area</loc>
      <lastmod>2021-07-19T13:07:32+00:00</lastmod>
      <priority>0.80</priority>
    </url>
</urlset>
```

robots.txt and sitemap.xml

```
└─$ curl http://10.49.183.225 -v
*   Trying 10.49.183.225:80 ...
* Established connection to 10.49.183.225 (10.49.183.225 port 80)
from 192.168.159.249 port 41590
* using HTTP/1.x
> GET / HTTP/1.1
> Host: 10.49.183.225
> User-Agent: curl/8.21.0
> Accept: */*
>
* Request completely sent off
< HTTP/1.1 200 OK
< Server: nginx/1.18.0 (Ubuntu)
< Date: Wed, 14 Oct 2026 22:00:24 GMT
< Content-Type: text/html; charset=UTF-8
< Transfer-Encoding: chunked
< Connection: keep-alive
< X-FLAG: THM{HEADER_FLAG}
< X-FLAG: THM{HEADER_FLAG}
< X-Powered-By: THM-Framework
<
```

Response headers




Framework admin portal

```
└─# gobuster dir -u 10.49.150.61 -w /usr/share/wordlists/seclists/Discovery/Web-Content/common.txt
===============================================================
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
===============================================================
[+] Url:                     http://10.49.150.61
[+] Method:                  GET
[+] Threads:                 10
[+] Wordlist:                /usr/share/wordlists/seclists/Discovery/Web-Content/common.txt
[+] Negative Status codes:   404
[+] User Agent:              gobuster/3.8.2
[+] Timeout:                 10s
===============================================================
Starting gobuster in directory enumeration mode
===============================================================
/assets               (Status: 301) [Size: 178] [--> http://10.49.150.61/assets/]
/contact              (Status: 200) [Size: 3108]
/customers            (Status: 302) [Size: 0] [--> /customers/login]
/development.log      (Status: 200) [Size: 27]
/monthly              (Status: 200) [Size: 28]
/news                 (Status: 200) [Size: 2538]
/private              (Status: 301) [Size: 178] [--> http://10.49.150.61/private/]
/robots.txt           (Status: 200) [Size: 46]
/sitemap.xml          (Status: 200) [Size: 1383]
```

Gobuster dir scan

```
└─# gobuster vhost -u "http://10.49.150.61" --domain acmeitsupport.thm -w /usr/share/wordlists/seclists
/Discovery/DNS/subdomains-top1million-5000.txt --append-domain --exclude-length 250-320
===============================================================
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
===============================================================
[+] Url:                     http://10.49.150.61
[+] Method:                  GET
[+] Threads:                 10
[+] Wordlist:                /usr/share/wordlists/seclists/Discovery/DNS/subdomains-top1million-5000.
txt
[+] User Agent:              gobuster/3.8.2
[+] Timeout:                 10s
[+] Append Domain:           true
[+] Exclude Length:          261,272,291,295,307,279,285,286,302,250,255,313,288,297,314,281,284,289,
309,311,253,265,266,269,294,303,304,306,258,277,254,256,260,270,278,290,251,282,317,283,296,316,280,299
,267,271,259,262,252,257,274,308,276,292,300,301,310,315,319,275,298,273,320,263,264,318,268,287,293,30
5,312
[+] Exclude Hostname Length: false
===============================================================
Starting gobuster in VHOST enumeration mode
===============================================================
blog.acmeitsupport.thm Status: 200 [Size: 58]
admin.acmeitsupport.thm Status: 200 [Size: 66]
shop.acmeitsupport.thm Status: 200 [Size: 58]
```

Gobuster vhost scan



Content Discovery completed

# 6. Result

All three rooms were completed. Observations from the lab targets and public data:

| # | Observation | Detail | Rating |
|---|---|---|---|
| 1 | Default admin credentials | The framework's admin portal accepted the default admin / admin login | High (lab) |
| 2 | Hidden paths listed publicly | robots.txt and sitemap.xml listed /staff-portal and /s3cr3t-area, and Gobuster found / monthly, /private and / development.log | Medium |
| 3 | Version banners | Web server banner `nginx/1.22.1` and an FTP banner with its version were readable without a login | Low |
| 4 | Public DNS and WHOIS data | Name servers, mail provider and subdomains of tryhackme.com were visible from public sources, with the registrant hidden by a privacy service | Informational |

# 7. Key Learnings

1. Passive recon sends nothing to the target and finds a lot (DNS, subdomains, exposed services). Active recon is more accurate but detectable and needs authorisation.
2. robots.txt and sitemap.xml are not security controls. They can point an attacker straight at sensitive paths, so those paths need real authentication.
3. Service banners and headers reveal software and versions, which can be matched with known vulnerabilities. Version details should be hidden and default credentials must be changed.
4. Tools such as Gobuster send thousands of requests, so scope and permission matter as much as the technique.

# Appendix: Commands Used

```
whois tryhackme.com
dig @1.1.1.1 tryhackme.com MX
ping -c 10 TARGET_IP
traceroute TARGET_IP
telnet TARGET_IP 80
nc TARGET_IP 21
gobuster dir -u http://TARGET -w /usr/share/wordlists/SecLists/Discovery/Web-Content/common.txt
gobuster vhost -u http://TARGET --domain example.thm -w SUBDOMAIN_LIST --append-domain
```